# Cyber Security Task 1 (2026)

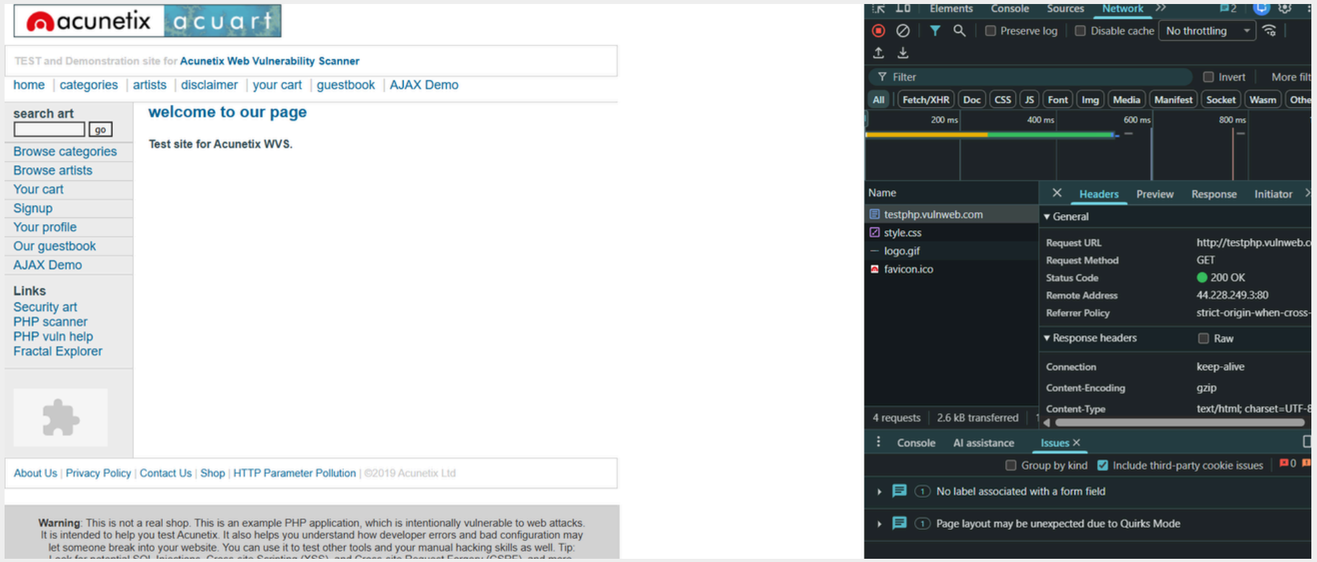
FUTURE INTERNS

# Vulnerability Assessment Report for a Live Website (Read-Only Scope)

In today's digital environment, websites are a critical part of business operations and brand presence. However, misconfigurations, outdated software, and missing security controls can expose organizations to cyber threats. A vulnerability assessment helps identify such weaknesses in a structured and ethical manner before they can be exploited.

This report presents the findings of a read-only vulnerability assessment conducted on a publicly accessible website using passive security analysis techniques. The objective was to evaluate visible security risks and provide practical recommendations to improve the overall security posture.

# Executive Summary




- A read-only vulnerability assessment was conducted on the public website: http://testphp.vulnweb.com
The purpose of this assessment was to identify publicly visible security weaknesses using passive analysis techniques without performing any intrusive testing or exploitation.
The assessment identified:
  - 1 High-risk issue
  - 1 Medium-risk issue
  - 1 Low-risk issue
The most critical finding involves the use of an outdated and unsupported PHP version, which increases exposure to known vulnerabilities. Additionally, several important HTTP security headers are missing, which weakens the site's defensive posture against common web attacks.
No critical service exposure or excessive open ports were identified.

# Scope of Assessment

The assessment strictly followed ethical guidelines.

Included:

- Public-facing pages only
- Passive scanning
- Header analysis
- Configuration review
- Port exposure analysis

Excluded:

- Login bypass attempts
- Brute force attacks
- Exploitation
- Denial-of-Service
- Active attack scanning

This was a non-intrusive vulnerability assessment.

# Methodology

The following tools were used:

- Nmap – Network exposure and service detection
- OWASP ZAP (Passive Mode) – Security misconfiguration detection
- Browser Developer Tools – HTTP header inspection

No active exploitation techniques were performed.

# Network Exposure Analysis

```
C:\Users\tejaswinikamat>nmap -sV testphp.vulnweb.com
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-01 12:19 +0530
Nmap scan report for testphp.vulnweb.com (44.228.249.3)
Host is up (0.26s latency).
rDNS record for 44.228.249.3: ec2-44-228-249-3.us-west-2.compute.amazonaws.com
Not shown: 999 filtered tcp ports (no-response)
PORT   STATE SERVICE VERSION
80/tcp open  http    nginx 1.19.0

Service detection performed. Please report any incorrect results at https://nmap.org/submit/
Nmap done: 1 IP address (1 host up) scanned in 60.84 seconds

C:\Users\tejaswinikamat>
```

- Tool Used: Nmap
  Command executed:

  nmap -sV testphp.vulnweb.com

  Results:
  - 1 host active
  - 1000 TCP ports scanned
  - 999 ports filtered
  - 1 open port detected:

  PortServiceVersion
  80
  HTTP
  nginx 1.19.0
  Analysis:
  The limited number of exposed ports indicates good perimeter-level filtering. However, the web server version is publicly disclosed.

# Finding 1: Server Version Disclosure

Risk Level: Low
Description:
The web server exposes its version (nginx 1.19.0) in HTTP responses.
Business Impact:
Version disclosure assists attackers during reconnaissance by allowing them to identify known vulnerabilities associated with that version.
Recommendation:
Disable server version disclosure in Nginx configuration:
server_tokens off;

# Application Layer Findings

**FINDING 2: OUTDATED PHP VERSION DISCLOSURE**

Evidence observed in HTTP header:

X-Powered-By: PHP/5.6.40

Risk Level: High

Description:

The application is running PHP version 5.6.40, which has reached End-of-Life and no longer receives security updates.

Business Impact:

Unsupported software increases exposure to publicly known vulnerabilities. Attackers may exploit documented weaknesses in outdated PHP versions.

Recommendation:

- Upgrade to a supported PHP version (PHP 8.x recommended).
- Disable X-Powered-By header:

expose_php = Off

# Finding 3: Missing Security Headers

The following important security headers were not present:

- Content-Security-Policy
- X-Frame-Options
- X-Content-Type-Options
- Strict-Transport-Security

Risk Level: Medium

Description:

The absence of recommended security headers reduces protection against common web-based attacks.

Business Impact:

This may increase exposure to:

- Cross-Site Scripting (XSS)
- Clickjacking
- MIME-type confusion attacks
- Protocol downgrade attacks

Recommendation:

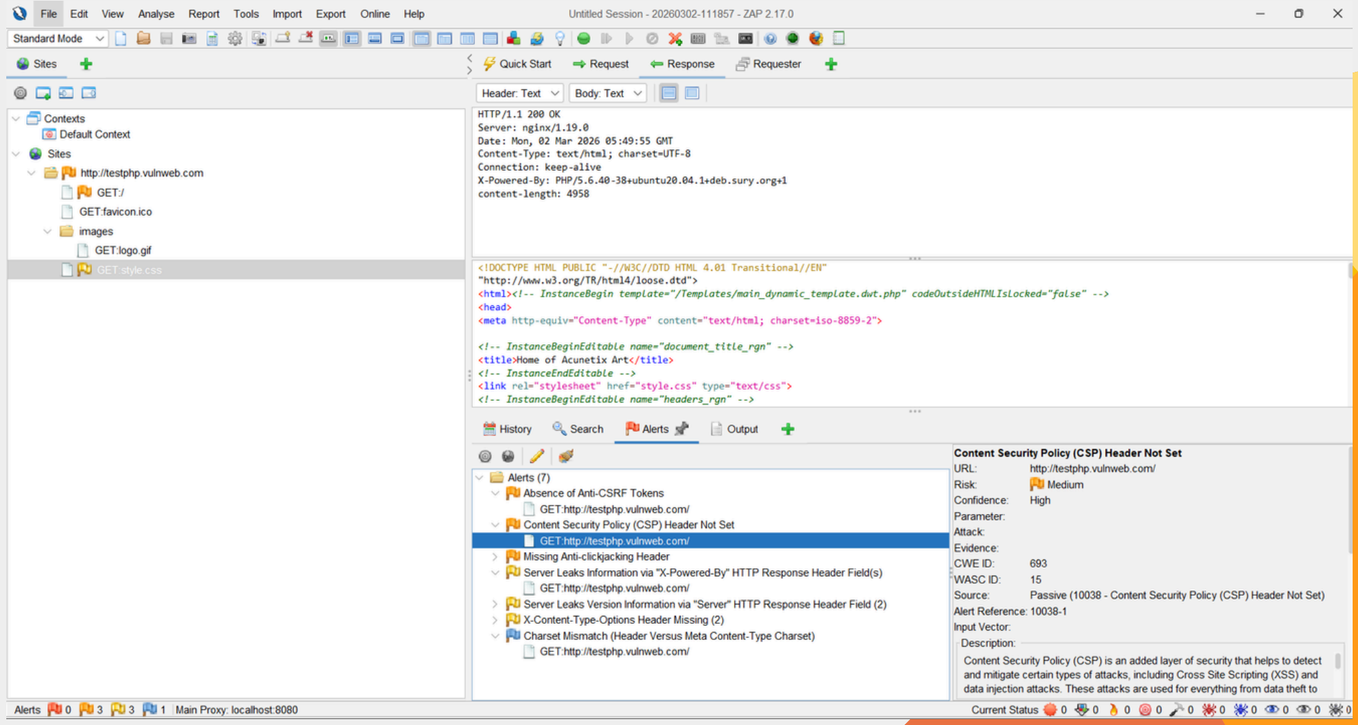
Implement recommended headers at the server level:

Example Nginx configuration:

```
add_header X-Frame-Options "SAMEORIGIN";
add_header X-Content-Type-Options "nosniff";
add_header Content-Security-Policy "default-src 'self';";
```

# OWASP ZAP Passive Scan Summary

Passive scanning identified:
4 Medium alerts
6 Low alerts
0 High alerts
Most alerts were related to:
Missing security headers
Information disclosure
Server version exposure
No critical remote code execution or SQL injection vulnerabilities were identified during passive analysis.



# Risk Summary

| Risk Level | Count |
|---|---|
| High | 1 |
| Medium | 1 |
| Low | 1 |
| Informational | Multiple |

# Overall Security Posture

The website demonstrates:

✓ Limited open ports

✓ Basic network filtering

✓ No critical remote services exposed

However, improvements are required in:

- Software version management
- HTTP security header implementation
- Information disclosure reduction

# Conclusion

- The website does not exhibit critical service exposure; however, configuration weaknesses and outdated software increase security risk.
  Immediate attention should be given to upgrading unsupported PHP versions and implementing recommended HTTP security headers to strengthen the overall security posture.
  With remediation, the security maturity of the website can be significantly improved.